



Overview



PENETRATION TEST REPORT

for

MEGAQUAGGA PUBLISHING



MQP

Version 1.0 (10/25/2025)

Prepared by **S M Mohiuddin Mahmood**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: This document contains proprietary and confidential information. 0x2A SECURITY guarantees the confidentiality of the information and any other material that has or will be disclosed during the performance of this service. A mutual non-disclosure agreement of confidential information is assumed between 0x2A SECURITY and MEGAQUAGGA PUBLISHING, limiting the use of confidential information exclusively for purposes associated with properly delivering this service.

EXECUTIVE SUMMARY

A security assessment was recently conducted on the web server and revealed critical security vulnerabilities that pose an immediate and severe risk to the organization. The core issue is the use of severely outdated software across the entire web environment, including the main website theme and multiple third-party components (like the "Social Warfare" plugin). Our testing demonstrated that these known, public flaws could be exploited with ease, allowing an unauthorized attacker to gain complete control of the web server, access sensitive, hidden data (such as passwords), and establish a platform for extending the attack across the network. The current setup is a major security liability that requires urgent attention to prevent catastrophic damage.

Our investigation began with a comprehensive digital scan of the web server, much like an automated security check-up. This process immediately flagged the use of outdated website software, extensions (plugins), and the primary site theme, identifying them as potential weak spots. To confirm the severity of these warnings, we performed a controlled test focusing on a well-known flaw in one of the older extensions. This test successfully demonstrated that a malicious party could, with minimal effort, exploit this weakness. We were able to effectively bypass the server's security defenses, gain access to sensitive information, and ultimately prove the potential for an attacker to completely compromise the system.

Compounding these technical flaws is a major operational failure: the web server currently has no configuration backup in place. This means that a successful attack—which our testing proved is easily achievable—would not only result in the potential loss of all data but also lead to major system downtime, high recovery costs, and significant damage to the company's reputation. Immediate and decisive action is required to fix these fundamental security gaps and restore a minimum level of protection. We strongly recommend a two-part remediation plan: First, immediately update all outdated software, plugins, and the website theme to their latest, secure versions. Second, urgently implement a robust and regularly scheduled backup process for all configurations and data to ensure business continuity and rapid recovery from any future security incident.



Scope

SCOPE

The scope of this assessment defines the boundaries and limitations of the penetration test to ensure clarity and compliance. This section outlines the specific target systems evaluated, their associated parameters, and the exclusions and restrictions applied during the engagement.

The objectives for this penetration test were clearly defined: to confirm that the vulnerabilities identified in the previous assessment could be successfully exploited, to simulate real-world attack scenarios to determine the true risk impact, and to provide actionable recommendations for remediation. The target system was strictly limited to the public-facing website at the domain www.megaquagga.local and its associated backend services. All other systems, including internal networks, unrelated subdomains, and third-party services, were explicitly excluded from the test. Furthermore, the engagement was conducted with strict limitations, focusing solely on the exploitation of known vulnerabilities without engaging in excessive brute-force attacks, Denial-of-Service (DoS) testing, or any actions that would result in data destruction or alteration.

Methodology

METHODOLOGY

This section describes the systematic approach followed during the penetration testing process. Each step is critical to ensure thorough evaluation of the target systems while adhering to ethical and procedural standards. The methodology is divided into several phases:

Pre-Engagement and Planning:

In pre-engagement and planning, we received documentation from Megaquagga about what the primary objective and target should be during our pentesting, as well as what to avoid and maintain limitations.

Information Gathering (Reconnaissance):

During Reconnaissance, our initial step was to check whether we have network connectivity to the website, and to do that, we tried pinging the server. Upon doing that, we noticed that our pings were being blocked by the firewall. To confirm if that's the case, we contacted Megaquagga, and they confirmed it was the firewall and permitted us to configure the firewall based on our needs during the pentesting. After configuring the firewall, we successfully established the network connection by pinging Megaquagga from our workstation.

Scanning:

The first step of our security assessment involved an automated digital check-up of the web server to find any structural weaknesses. This was achieved by using a specialized scanning tool, wpscan, which automatically identified all outdated software, extensions (plugins), and the website's theme that contained known public vulnerabilities. This process provided us with all the necessary information to precisely target the weakest points, specifically pointing us toward an older, vulnerable plugin for our controlled exploitation test.

Exploitation:

The exploitation phase focused on proving that the identified vulnerabilities could be successfully used by an attacker. After finding multiple weak spots, the team chose to target a **known, severe flaw** in the oldest version of a website add-on (the Social Warfare plugin). This flaw was confirmed to be a widely documented public vulnerability (identified as **CVE-2019-9978**), which established its high-risk level. The team then successfully demonstrated a **two-step attack simulation**: first, they exploited one aspect of

the flaw to **force the system to expose hidden, sensitive data** from the web server. Second, they leveraged a different, more critical weakness to **remotely execute a special administrative tool**, proving an attacker could gain a high level of control over the website's core system.

Post-Exploitation:

The post-exploitation phase focused on determining the maximum potential damage an attacker could inflict after successfully breaking in. Once a basic connection was established, we upgraded our access to a **powerful administrative control tool**. This allowed us to perform a realistic simulation of a persistent attack. Specifically, we demonstrated how an attacker could **increase their security clearance** on the server (known as privilege escalation) and tested the ability to **jump from the compromised web server to other internal network systems**. This final step confirmed that the security flaws were severe enough to lead to critical consequences, including network-wide damage, data theft, and the establishment of a lasting presence on the internal infrastructure.

Reporting:

For our reporting part of the methodology, we are crafting a Pentesting report, which will describe what we did during this pentesting, what we found, and what can happen if an actual attacker wants to break their way into the megaquagga web server. As well as the recommendation on how to fix these vulnerabilities, all with non-technical words to make sure everybody understands our report when they go over it.



Findings

FINDINGS

This section presents the vulnerabilities identified during the penetration test, along with their potential impact and evidence collected. The findings are categorized by severity to assist in prioritizing remediation efforts.

CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

Vulnerability	Outdated WordPress plugin Version (social_warfare)
CVE	CVE-2019-9978
Severity	Medium ▾ (CVSS SCORE: 6.1)
OWASP Top 10	A06 (Vulnerable and outdated components) ▾
Risk	Publicly available exploits such as XSS and RCE exist
Steps to exploit	1. Creating a Payload and hosting in the RedTeam VM 2. Crafting a malicious url which includes the payload 3. Verifying the use of the payload. 4. Replace test payload with reverse shell. 5. Upgradin shell to a meterpreter implant.
Evidence	https://docs.google.com/document/d/1j86b8NQVYcg9r3HCvuVJKidTdnC-H40GI9I-urf8pXs/edit?usp=sharing

EXPLOITATION AND POST-EXPLOITATION

The exploitation phase involved leveraging identified vulnerabilities to compromise the target systems, followed by post-exploitation activities to assess the potential impact. This section provides a detailed account of the actions taken.

EXPLOITATION PHASE

- Exploited CVE-2019-9978 which is the vulnerability associated with the wordpress plugin "social_warfare"

- Successfully hosted a crafted malicious URL payload in the http port of the python server
- Triggered the payload using that URL, which caused the target system to download and execute the reverse shell.
- Establish a command shell connection through the port 443 by using the metasploits multihandler
- Verified reverse shell working by command whoami

POST-EXPLOITATION PHASE

- Upgraded the reverse shell to meterpreter implant
- Executed sysinfo to gather information about the target's system.
- Captured internal IP address along with other valuable information.
- Proved that these vulnerabilities can lead to extreme damage including full system loss to attackers.

Recommendations

RECOMMENDATIONS

This section outlines the recommended actions to address the identified vulnerabilities and enhance the security posture of the target systems. Implementing these measures will help mitigate risks and prevent potential exploitation.

Recommendation #1: Update outdated software

Through our extensive research, we have identified multiple vulnerabilities that a sophisticated attacker could exploit. All of the vulnerabilities have one thing in common, which is that they are all outdated. From the WordPress core version to the plugins, everything is outdated. Newly released version of WordPress, the theme and the plugins need to be installed and deployed ASAP!

Recommendation #2: Add VM

Having a VM constantly monitor the system reduces a lot of manual labor. A VM constantly looks for vulnerabilities in the system, whether it is an outdated system or if something broke in, VM will be there to alert.

Recommendation #3: ADD PM

Patch Management is another crucial tool for this because it will also reduce manual labor and replace it with automation. A patch management hunts for outdated systems and reactively deploys newer versions of software, updating all the old ones.



Conclusion

CONCLUSION

Should the findings of our security team be given due consideration and our recommendations implemented, existing vulnerabilities will be rectified, and future manual efforts will largely be superseded by automation.